

4 Common Open Source License Compliance Failures and How to Avoid Them

4 Common Open Source License Compliance Failures and How to Avoid Them

Created on 2017-02-02 23:10

Published on 2017-02-06 20:55

Companies or organizations that don't have a strong open source compliance program often suffer from errors and limitations in processes throughout the software development cycle that can lead to open source compliance failures.

The previous article in this series covered common intellectual property failures. This time, we'll discuss the four common open source license compliance failures and how to avoid them.

License compliance problems are typically less damaging than intellectual property problems, as they don't have the side effect of forcing you to release your proprietary source code under an open source license. But license compliance failures may still have serious consequences including:

- An injunction preventing a company from shipping a product until source code is released.
- Support or customer service headaches as a result of version mismatches (as a result of people calling or emailing the support hotline and inquiring about source code releases).
- Embarrassment and/or bad publicity with customers and open source community.

4 Common OS License Compliance Failures

<i>Problem Type</i>	<i>How to Avoid</i>
Failure to publish or make available source code packages as part of meeting license obligations	Follow a detailed compliance checklist to ensure that all compliance action items have been completed when a given product, application, or software stack is released into the market
Failure to provide correct version of the source code corresponding to the shipped binaries	Add a verification step into the compliance process to ensure that you're publishing the version of source code that exactly corresponds to the distributed binary version
Failure to release modifications that were introduced to the open source software being incorporated into the shipping product	Use a bill of material (BOM) difference tool that allows the identification of software components that change across releases Re-introduce the newer version of the software component in the compliance process Add the "compute diffs" of any modified source code (eligible for open source distribution) to the checklist item before releasing open source used in the product
Failure to mark open source code that has been changed or to include a description of the changes	Add source code marking as checklist item before releasing source code to ensure you flag all the source code introduced to the original copy you downloaded Conduct source code inspections before releasing the source code Add milestone in compliance process to verify modified source code has been marked as such Offer training to staff to ensure they update the change logs of source code files as part of the development process

Problem #1: Failure to publish or make available source code packages as part of meeting license obligations

How to avoid it: Follow a detailed compliance checklist to ensure that all compliance action items have been completed when a given product, application, or software stack is released into the market.

Problem #2: Failure to provide correct version of the source code corresponding to the shipped binaries.

How to avoid it: Add a verification step into the compliance process to ensure that you're publishing the version of source code that exactly corresponds to the distributed binary version.

Problem #3: Failure to release modifications that were introduced to the open source software being incorporated into the shipping product.

How to avoid it:

- Use a bill of material (BOM) difference tool that allows the identification of software components that change across releases
- Re-introduce the newer version of the software component in the compliance process
- Add the “compute diffs” of any modified source code (eligible for open source distribution) to the checklist item before releasing open source used in the product.

Problem #4: Failure to mark open source code that has been changed or to include a description of the changes.

How to avoid it:

- Add source code marking as checklist item before releasing source code to ensure you flag all the source code introduced to the original copy you downloaded
- Conduct source code inspections before releasing the source code
- Add a milestone in the compliance process to verify modified source code has been marked as such
- Offer training to staff to ensure they update the change logs of source code files as part of the development process.

The most important outcome of non-compliance cases has been that the companies involved ultimately had to comply with the terms of the license(s) in question, and the costs of addressing the problem after the fact has categorically exceeded those of basic compliance.

Therefore, it is really a smart idea to ensure compliance before a product ships or a service launches. In the next article of this series, we'll cover some of the top lessons learned in achieving open source compliance that open source professionals need to know.

The following is adapted from "Open Source Compliance in the Enterprise" published by The Linux Foundation (free e-book download), a complete guide to creating compliance processes and policies for your organization.

Original post appeared on [Linux.com](#).
